

Área de Conocimiento de Tecnología de la Información y Comunicación

Auditoria de Sistemas

Elaborado por:

Br. Gerson Antonio
Valdivia

Br. Stephanie Lucía
Mora Chávez

Br. Haxell Antonio
Trejos Rodríguez

Br. Alison Michelle
Navarro Goussen

Br. Arleth del Rosario
Velásquez Gómez

Docente:

Msc. Leonel Antonio Martínez Zuniga

21 de abril, 2026
Managua, Nicaragua

En grupo de trabajo, se les asignará 2 tipos de auditoría y sobre ello deben de desarrollar lo siguiente:

Auditoría asignada: Base de datos

Contexto del Modelo de Negocio: Concesionaria de Vehículos.

Naturaleza de los Datos: Bajo volumen transaccional, pero de altísimo valor financiero y legal. El núcleo del sistema maneja inventario de alto costo (números de chasis/VIN), historiales crediticios de clientes, contratos de financiamiento y bitácoras de mantenimiento de taller.

1. Aspectos que deben de ser evaluados.

1. Amenazas (Factores externos o internos)

- **Fraude Interno:** Empleados (vendedores o cajeros) intentando alterar el sistema de información para modificar tasas de interés, comisiones de venta o aprobar historiales crediticios rechazados.
- **Ataques Dirigidos (Ransomware):** Cibercriminales que saben que una concesionaria maneja datos financieros sensibles e intentan secuestrar la base de datos de clientes para extorsionar.
- **Fallas Físicas Catastróficas:** Un incendio, inundación o fallo eléctrico severo en el centro de datos local que corrompa los discos duros donde reside el motor de la base de datos principal.

2. Vulnerabilidades (Debilidades estructurales)

- **Deficiencia en la Nomenclatura y Estructura:** Tablas y campos nombrados sin estándares un ejemplo puede ser usar Tabla_1 en lugar de Tbl_Cliente_Financiamiento, lo que imposibilita la trazabilidad de los datos y dificulta el análisis forense si hay un fraude.
- **Ausencia de Índices Críticos:** Tablas transaccionales pesadas que no tienen índices en campos clave (como el Número de Chasis o la Cédula del cliente), causando que el sistema se congele al generar reportes de ventas mensuales.
- **Logs y Bitácoras Desactivadas:** El motor de base de datos no tiene activada la auditoría nativa. No hay un historial que registre qué usuario hizo un *UPDATE* o *DELETE* en la tabla de pagos de clientes.
- **Falta de Redundancia Geográfica:** La base de datos opera de manera aislada en un servidor local. No existe un esquema de alta disponibilidad en la nube para garantizar la supervivencia de los datos si el servidor físico falla.

3. Riesgos (Impacto directo al negocio)

- **Riesgo Operativo (Pérdida de Inventario):** La corrupción de la estructura de tablas y la falta de respaldos puede causar la pérdida total de los historiales de mantenimiento y garantías de los vehículos vendidos, paralizando el taller y las ventas.

- **Riesgo Financiero (Robo Silencioso):** Debido a la falta de bitácoras de auditoría profunda, una modificación fraudulenta en el precio de venta de un vehículo o en el saldo de una deuda podría pasar desapercibida por meses.
- **Riesgo Legal y de Cumplimiento:** Una brecha de seguridad que exponga los datos crediticios, salarios y direcciones de los clientes puede resultar en demandas millonarias y la pérdida irreversible de la reputación de la concesionaria.

Categoría de evaluación	Aspectos a evaluar
Seguridad y control	Gestión de riesgos: Se analiza la posibilidad de que un empleado altere el precio de venta de un vehículo, elimine historiales de mantenimiento o exfiltre la base de datos de clientes VIP a la competencia. Se evalúan los controles preventivos y detectivos. Control de accesos: Se verifica la segregación de funciones: un vendedor solo debe poder cotizar, mientras que solo el gerente financiero debe tener el privilegio de aprobar créditos o aplicar descuentos.
Integridad de la información	Validación y consistencia de datos: Se revisa que exista coherencia absoluta; por ejemplo, que un vehículo facturado pase automáticamente a estado "Vendido" y que no existan dos registros con el mismo Número de Chasis (VIN). Protección contra alteraciones: Se comprueba que, una vez firmado el contrato de financiamiento, el registro quede bloqueado para evitar modificaciones fraudulentas en las tasas de interés.
Disponibilidad y continuidad	Operatividad del servicio: Se evalúa si la base de datos está disponible de forma continua, especialmente durante los cierres de mes donde se procesan la mayor cantidad de facturaciones. Tolerancia a fallos: Se analiza si existe redundancia (como servidores en espejo) para que, si el servidor físico de la agencia falla, la sala de ventas y el taller mecánico puedan seguir operando.
Respaldo y recuperación	Copias de seguridad: Se verifica la frecuencia de los respaldos diarios de las transacciones financieras y contratos, así como su almacenamiento seguro en una ubicación externa o en la nube. Restauración de información: Se comprueba si la concesionaria realiza simulacros para medir cuánto tiempo tardarían en recuperar la base de datos tras un ataque de Ransomware.
Configuración y mantenimiento	Seguimiento de cambios (Logs): Se evalúa si el motor de BD registra la bitácora exacta de quién autorizó la salida de un vehículo del inventario, desde qué computadora y a qué hora.

	Parámetros del motor y Actualizaciones: Se analiza si el software de la base de datos está parchado contra vulnerabilidades conocidas que podrían permitir el secuestro de la información.
Protección de información sensible	Clasificación de datos: Se identifica el tratamiento de los datos críticos: números de chasis, salarios de clientes, historiales crediticios y direcciones particulares. Mecanismos de protección: Se revisa que los datos financieros de los compradores estén estrictamente cifrados y no viajen en texto plano por la red de la agencia.

2. CRITERIOS, ESTÁNDARES, NORMATIVAS Y LEYES CONSIDERADAS

2.1 ESTÁNDARES TÉCNICOS E INTERNACIONALES Marcos técnicos específicos aplicados al aseguramiento de la base de datos de la concesionaria:

- **CIS Benchmarks (Center for Internet Security):** Utilizado como estándar de oro para el "Hardening" de la base de datos, asegurando que no existan contraseñas por defecto que permitan a un atacante acceder al inventario de vehículos.
- **ISO/IEC 27001 (Control A.12.6 - Gestión de Vulnerabilidades Técnicas):** Enfocado en verificar que el motor de base de datos reciba los parches de seguridad necesarios para proteger la información financiera de los clientes contra ciberataques.
- **OWASP (Top 10 - Inyección de SQL):** Estándar para auditar que el portal web (donde los clientes aplican a créditos vehiculares) no permita inyectar código malicioso que vulnere la base de datos central.
- **Estándares de Codificación y Nomenclatura:** Verificación de que el diseño del esquema siga estándares institucionales para garantizar la mantenibilidad y eficiencia de los reportes.

2.2 METODOLOGÍAS Y MARCOS DE GESTIÓN (FRAMEWORKS) Estructuras de gobernanza aplicadas a la gestión de los datos del negocio:

- **DAMA-DMBOK (Data Management Body of Knowledge):** Marco fundamental para auditar la "calidad de los datos". Se utiliza para asegurar que no existan registros duplicados de clientes o vehículos sin número de chasis (VIN).
- **COBIT 2019 (Dominio BAI04 - Gestión de la Disponibilidad y Capacidad):** Utilizado para auditar si el servidor de base de datos tiene el rendimiento necesario para soportar las consultas simultáneas de los vendedores, cajeros y mecánicos.
- **ITIL v4 (Gestión de la Configuración y el Cambio):** Se aplica para asegurar que cualquier cambio en el esquema (ej. agregar un nuevo "Impuesto de importación") pase por un proceso formal de aprobación en un ambiente de pruebas (QA) antes de pasarlo a producción.

2.3 MARCO LEGAL Y CUMPLIMIENTO REGULATORIO Implicaciones legales sobre la tenencia y procesamiento de datos en la concesionaria:

- **Leyes de Protección de Datos Personales (GDPR / Leyes Nacionales como la Ley 921):** Obligatoriedad de técnicas de anonimización. *Aplicación:* Si TI prueba un nuevo módulo, no deben tener acceso a los salarios reales ni números de cédula de los clientes.
- **PCI-DSS (Payment Card Industry Data Security Standard):** De cumplimiento obligatorio si se almacena información de tarjetas de crédito. *Aplicación:* Aplica si la concesionaria procesa pagos de primas o facturas de taller mediante tarjetas y guarda esos registros.
- **Leyes de Retención de Datos:** Auditoría de las políticas de purga de datos. *Aplicación:* Auditar que los contratos de financiamiento y garantías no se borren accidentalmente y se mantengan el tiempo que exigen las leyes fiscales.
- **Soberanía de Datos:** Verificación de la ubicación física de los datos. *Aplicación:* Si la agencia guarda sus copias de seguridad en la nube, se debe verificar en qué país están esos servidores para no infringir regulaciones sobre la exportación de información crediticia ciudadana.

3. OFERTA DE AUDITORIA

Proyecto: Auditoría Integral de Seguridad y Cumplimiento de Base de Datos.

I. Objetivo General

Evaluar la eficacia de los controles de seguridad, integridad y disponibilidad aplicados al motor de base de datos, identificando brechas respecto a las mejores prácticas de la industria.

II. Alcance Técnico

1. **Revisión de Configuración de Seguridad:** Análisis del endurecimiento (*Hardening*) del DBMS.
2. **Gestión de Accesos:** Revisión de roles, privilegios, perfiles de usuario y políticas de contraseñas.
3. **Seguridad de los Datos:** Verificación de mecanismos de cifrado (TDE), enmascaramiento y copias de seguridad.
4. **Auditoría de Eventos:** Evaluación de la configuración de logs y monitoreo de actividad (DAM).
5. **Pruebas de Vulnerabilidades:** Escaneo especializado sobre el motor para detectar fallos de parcheo.

III. Entregables

1. **Informe Ejecutivo:** Resumen de riesgos para la alta dirección.

2. **Informe Técnico Detallado:** Listado de hallazgos con evidencia, nivel de riesgo y recomendaciones de remediación.
3. **Matriz de Seguimiento:** Plan de acción sugerido.

4. Bosquejo de la estructura general del cronograma de auditoría.

Fase 1: Planificación y Reconocimiento (Semana 1)

1. Reunión de apertura (Kick-off).
2. Solicitud de documentación (políticas, inventarios, diagramas de red).
3. Definición de usuarios y accesos temporales para el auditor.

Fase 2: Ejecución y Pruebas de Campo (Semana 2-3)

1. **Entrevistas:** Con administradores de BD (DBAs) y responsables de seguridad.
2. **Revisión Técnica:** Extracción de configuraciones y revisión de scripts.
3. **Pruebas de Cumplimiento:** Verificación de que lo que dicen los manuales se cumple en la realidad.
4. **Análisis de Vulnerabilidades:** Ejecución de herramientas de escaneo.

Fase 3: Análisis de Hallazgos y Borrador (Semana 4)

1. Correlación de datos obtenidos.
2. Clasificación de hallazgos (Crítico, Alto, Medio, Bajo).
3. Redacción del informe preliminar.

Fase 4: Cierre y Entrega (Semana 5)

1. Reunión de validación de hallazgos con el área técnica (para evitar falsos positivos).
2. Presentación final de resultados a la gerencia.
3. Entrega del informe final firmado.

Auditoría asignada: Gestión informática

1. Aspectos que deben de ser evaluados.

A. Amenazas

- **Accesos no autorizados a sistemas**
 - Uso indebido de cuentas activas de ex empleados
- **Incumplimiento de procesos administrativos**
 - Compras fuera de normativa
- **Errores humanos**
 - Eliminación de datos o mala gestión de accesos
- **Falta de control en adquisiciones**
 - Compras sin presupuesto o sin autorización
- **Fugas de información**
 - Mal manejo de datos sensibles
- **Interrupción de operaciones**
 - Falta de planes de contingencia
- **Dependencia de personal clave**
 - Conocimiento no documentado
- **Fallas en contratos de servicios TI**
 - Incumplimiento de proveedores

B. Vulnerabilidades

- **Ausencia de plan estratégico de TI**
- **Falta de planes de mantenimiento**
- **No existen manuales de control interno**
- **Procesos administrativos no documentados**
- **Falta de control en:**
 - Compras (caja chica, cotización, compra directa)
- **Inexistencia de mecanismos de acceso físico:**
 - Biometría
 - Tarjetas electrónicas
- **Gestión deficiente de inventarios**
- **Falta de control en cambios de activos**
- **No desactivación de usuarios al salir empleados**
- **Ausencia de planes de contingencia**
- **Falta de control sobre contratos de TI**

C. Riesgos

Riesgo	Causa	Impacto
Acceso indebido a sistemas	Usuarios activos sin control	Alto
Pérdida de información	Falta de control y respaldo	Crítico
Compras irregulares	Falta de normativa	Alto
Interrupción del servicio	Sin plan de contingencia	Crítico
Descontrol de activos	Inventario deficiente	Medio-Alto
Incumplimiento contractual	Mala gestión de contratos	Alto
Fraude interno	Falta de controles administrativos	Alto

2. CRITERIOS, METODOLOGÍAS, ESTÁNDARES, NORMATIVAS Y LEYES

Criterios de auditoría

- Cumplimiento de políticas internas
- Eficiencia en la gestión de TI
- Control de procesos administrativos
- Seguridad de la información
- Continuidad del negocio

Metodologías

- Auditoría basada en riesgos
- Evaluación del proceso administrativo (Planificación, Organización, Dirección, Control)
- Análisis de procesos
- Técnica de los **5 Porqués**
- Evaluación de controles internos

Estándares internacionales

- ISO/IEC 27001
- ISO 19011
- ISO 27005

Marcos de referencia

- COBIT 2019
- COSO (control interno)

Normativas y leyes

- Ley 921
- Legislación interna de la organización
- Reglamentos de contratación y adquisiciones

3. OFERTA TÉCNICA DE AUDITORÍA**1. Fundamentación**

La auditoría de gestión informática se propone evaluar el grado en que las Tecnologías de Información son administradas de forma eficiente, segura y alineada con los objetivos estratégicos de la organización.

Se enfoca en:

- Evaluación gerencial de TI
- Control de procesos administrativos
- Identificación de riesgos
- Mejora continua

2. Objetivos**Objetivo general:**

Evaluar la gestión de TI en la organización, identificando debilidades, riesgos y oportunidades de mejora.

Objetivos específicos:

- Analizar el proceso administrativo de TI
- Evaluar controles internos
- Verificar cumplimiento de políticas
- Analizar la gestión de accesos y activos
- Evaluar continuidad del negocio

3. Alcance

Incluye:

- Planificación estratégica de TI
- Procesos administrativos (compras, presupuestos)
- Gestión de inventarios
- Control de accesos
- Contratos de TI
- Continuidad del negocio

4. Plan de trabajo

Fases:

1. Revisión documental
2. Evaluación del proceso administrativo
3. Evaluación de controles internos
4. Análisis de riesgos
5. Elaboración de informe final

5. Entregables

- Informe de auditoría
- Matriz de riesgos
- Hallazgos (no conformidades, observaciones)
- Recomendaciones
- Plan de mejora

4. Bosquejo de la estructura general del cronograma de auditoría.

Fase 1: Planificación y Reconocimiento (Semana 1)

- 1. Reunión de apertura (Kick-off)**
 - Presentación del equipo auditor
 - Definición del alcance y objetivos
 - Alineación con la alta gerencia
- 2. Solicitud y recopilación de documentación**
 - Plan estratégico de TI
 - Planes de mantenimiento
 - Manuales de control interno
 - Políticas y normas de TI
 - Contratos de servicios y mantenimiento
- 3. Definición de accesos para auditoría**
 - Asignación de permisos temporales
 - Coordinación con responsables de TI
 - Identificación de áreas críticas
- 4. Identificación de procesos clave de TI**

- Procesos administrativos (compras, presupuestos)
- Gestión de inventarios
- Gestión de accesos

Fase 2: Ejecución y Evaluación (Semana 2 – 3)

- 1. Entrevistas al personal clave**
 - Responsables de TI
 - Personal administrativo
 - Encargados de control interno
- 2. Evaluación del proceso administrativo de TI**
 - Planificación (estrategia, presupuestos, mantenimiento)
 - Organización (roles, estructura, recursos)
 - Dirección (toma de decisiones, supervisión)
 - Control (seguimiento y cumplimiento)
- 3. Revisión de procesos administrativos**
 - Procesos de adquisiciones (caja chica, cotización, compra directa)
 - Cumplimiento de normativas internas
 - Control de inventarios y activos
- 4. Evaluación de controles de acceso**
 - Acceso físico a áreas críticas
 - Gestión de usuarios en sistemas
 - Procedimientos ante salida de empleados
- 5. Verificación de continuidad del negocio**
 - Existencia de planes de contingencia
 - Procedimientos ante fallos o incidentes

Fase 3: Análisis de Hallazgos (Semana 4)

- 1. Integración y análisis de información recolectada**
 - Cruce de datos documentales vs realidad operativa
- 2. Identificación de debilidades**
 - Vulnerabilidades en procesos
 - Fallas en controles internos
- 3. Evaluación de riesgos**
 - Probabilidad e impacto
 - Priorización de riesgos
- 4. Clasificación de hallazgos**
 - Críticos
 - Altos
 - Medios
 - Bajos
- 5. Elaboración del informe preliminar**

Fase 4: Cierre y Presentación (Semana 5)

- 1. Validación de hallazgos**
 - Reunión con responsables de TI
 - Confirmación de evidencias
 - Eliminación de posibles falsos positivos
- 2. Presentación de resultados a la gerencia**
 - Exposición de riesgos
 - Impacto en la organización
 - Nivel de madurez de la gestión de TI
- 3. Entrega del informe final**
 - Informe de auditoría
 - Matriz de riesgos
 - Recomendaciones
- 4. Propuesta de plan de mejora**
 - Acciones correctivas
 - Priorización por impacto
 - Plazos de implementación